COMPTIA SECURITY+ SY0-701 | DOMAIN 1 · GENERAL SECURITY CONCEPTS (12%)

Security+ 1.1 · Security Controls

Mestre CyberSec · **Lesson 1.1 — Security Controls** (11:48) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Controle = qualquer medida que evita, avisa, conserta ou compensa. 4 CATEGORIAS (by means): Technical (ferramenta), Managerial (documento/política), Operational (pessoas no dia-a-dia), Physical (barreira física). 6 TIPOS (by purpose): Preventive (barra antes), Deterrent (desanima

💡 Key Exam Highlights & Critical Concepts

- Matriz 4×6 = a tabela mental da aula
- Preventive barra ANTES — Detective AVISA — Corrective CONCERTA
- Compensating: usa MEIOS DIFERENTES quando o ideal não dá — temporário
- Directive = o mais fraco: 'authorized personnel only' não barra ninguém
- Antivírus: technical + preventive e detective dependendo do modo
- Extintor de incêndio = corrective — repara durante, NÃO previne

🎯 Exam Tips & Typical CompTIA Scenarios

- Gatilhos: 'after the event'→corrective · 'discourage'→deterrent · 'identifies/logs'→detective · 'alternative approach'→compensating
- A pergunta do Messer: 'what CATEGORY does it fit in (technical/managerial/operational/physical) AND what TYPE?'

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 1.1 — Security Controls)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Control Categories

The four groups describing HOW a control is implemented (its means): Technical (technology tools), Managerial (policies, procedures and processes), Operational (people performing day-to-day activities), and Physical (real-world barriers).

⚠️ ***Exam Trap:*** *Pergunta-padrão da prova: 'qual a categoria?'. Antivírus/firewall/criptografia/ACL = Technical; política AUP/avaliação de risco = Managerial; treinamento, resposta a incidentes e guarda executando a função = Operational; cerca, tranca, câmera = Physical. Cruze cada categoria com um tipo para montar a matriz 4×6 mental da aula.*

• Control Types

The six groups describing WHY a control exists (its purpose): Preventive, Deterrent, Detective, Corrective, Compensating, and Directive.

⚠️ ***Exam Trap:*** *Gatilho na questão: 'purpose/goal' = Tipo; 'means/how implemented' = Categoria. Resumo de 6 palavras: Preventive BARRA antes; Detective AVISA; Corrective CONCERTA; Deterrent DESANIMA; Compensating USA MEIO DIFERENTE; Directive apenas ORIENTA (o mais fraco).*

• Preventive Control

A control that blocks an incident before it occurs, denying the unwanted activity in advance (e.g., firewall rules, access control lists, access badges).

⚠️ ***Exam Trap:*** *Palavra-chave na prova: 'block/deny'. Firewall e ACL = technical + preventive. Cuidado com o antivírus: só é preventive em modo de bloqueio em tempo real; em modo de varredura/detecção ele vira detective.*

• **Detective Control**

A control that identifies and records an incident while or after it happens, alerting that a violation has occurred (e.g., log review, monitoring, alarm systems).

⚠ ***Exam Trap:*** *Gatilho: 'identifies/alerts/records' — detecta e avisa, mas NÃO impede nada. Logs e monitoramento contínuo = detective. Câmera gravando = physical + detective; a mesma câmera visível com placa de aviso atua como deterrent.*

• **Corrective Control**

A control that repairs, fixes or restores a system during or after an incident to reduce its impact (e.g., fire extinguisher, restoring from backup, contingency site).

⚠ ***Exam Trap:*** *Clássico pegadinha da prova: EXTINTOR = corrective, pois conserta DURANTE o incêndio — não é preventive. Backup restaurado após falha/ataque = corrective. Palavras-chave: 'fix', 'restore', 'reduce impact', 'repair'.*

• **Deterrent Control**

A control that discourages an attacker from even attempting a violation, without actively blocking the action (e.g., warning signs, motion-activated lights, visible guard).

⚠ ***Exam Trap:*** *Distinção-chave: deterrent DESANIMA mas não barra (preventive BARRA de verdade). Placa 'monitorado por câmeras' = deterrent. Não confunda com directive: a placa deterrent implica consequência/punição; a directive apenas orienta.*

• **Compensating Control**

An alternative control used when the ideal or required control cannot be implemented, providing a similar level of protection through different means, often temporarily.

⚠ ***Exam Trap:*** *Gatilho na prova: 'when the ideal/required control cannot be used', 'alternative measure', 'similar protection using a different means'. Ex.: sistema legado sem atualização disponível → segmentação e monitoração intensiva como compensating (solução de ponte, não definitiva).*

• **Directive Control**

A control that guides or directs behavior through procedures, signs or policies, technically enforcing nothing (e.g., 'authorized personnel only' sign).

⚠ ***Exam Trap:*** *O MAIS FRACO dos 6 tipos: não barra, não desanima com punição, não detecta — apenas orienta. 'Authorized personnel only' não impedirá ninguém tecnicamente. Se na questão algo é efetivamente enforced (aplicado), NÃO é directive.*

🏛 Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Control Categories: Technical, Managerial, Operational, and Physical

🏠 **Real-World Analogy:** Consider high-security commercial bank defense. Managerial controls are the corporate governance manuals and board-approved security policies; Physical controls are reinforced concrete walls, armored turnstiles, and perimeter fencing; Technical controls are automated laser sensors, digital keypad biometric vaults, and data encryption; Operational controls are human-driven daily routines, such as security guards verifying employee badges and tellers locking cash drawers during breaks.

🔍 **Root Cause & Background:** No single control layer is invulnerable. If an organization invests millions in cutting-edge firewalls (technical) but neglects security awareness training (operational) or lacks board-enforced administrative policies (managerial), adversaries will effortlessly breach the perimeter by exploiting human error.

🛡 **GRC Auditor Perspective:** GRC auditors classify safeguards into structured catalogs like NIST SP 800-53 or ISO/IEC 27001 Annex A. They audit tangible artifacts: executive-signed security charters (managerial), firewall rulebases and IAM permission logs (technical), anti-phishing training attendance rosters (operational), and facility physical barrier inspection records (physical).

⚠ **How CompTIA Tests This:** CompTIA exam trigger: 'Identify the control CATEGORY'. Instant clue: Software, hardware, encryption, or ACLs = Technical. Written policies, governance charters, and risk assessments = Managerial. Day-to-day human execution, awareness training, and onboarding checks = Operational. Fences, gates, guards, lighting, and locks = Physical.

📌 Functional Types: Preventive vs. Deterrent vs. Directive

🏠 **Real-World Analogy:** A heavy steel gate locked with a biometric scanner is Preventive (it physically and logically obstructs unauthorized passage). A prominent warning sign stating 'Warning: 24/7 Armed Guard and K9 Patrol' is Deterrent (it does not physically stop an intruder, but psychologically discourages them via fear of apprehension). An office policy sign declaring 'Authorized Personnel Only' or the corporate acceptable use policy is Directive (it formally prescribes required behavioral compliance).

🔍 **Root Cause & Background:** To safeguard corporate assets efficiently, defense-in-depth requires tiered behavioral friction: first discouraging opportunistic intrusion attempts (deterrent and directive) to diminish threat volume, followed by absolute barrier enforcement (preventive) when an attack occurs.

🛡️ **GRC Auditor Perspective:** Auditors execute control validation tests: confirming that preventive safeguards actively deny unauthorized transactions (e.g., pen-testing doors or testing firewall deny rules) while validating that directive and deterrent signage and compliance banners are legally vetted, prominent, and up to date.

⚠️ **How CompTIA Tests This:** Exam scenario cues: 'Discourages or dissuades unauthorized actions' -> Deterrent. 'Stops or impedes an attack before damage occurs' (e.g., IPS, access control list, mantrap, account lockout) -> Preventive. 'Mandates behavioral compliance and procedures' -> Directive.

📌 Functional Response Types: Detective vs. Corrective

🏠 **Real-World Analogy:** A smoke detector sounding a loud siren in the ceiling is Detective (it instantly identifies and alerts that combustion is occurring, yet cannot extinguish a single ember). The handheld fire extinguisher, the automatic ceiling water sprinklers, and restoring clean backups after a malware outbreak are Corrective (intervening during or after the catastrophe to mitigate harm and restore operational state).

🔍 **Root Cause & Background:** No preventive wall is impenetrable; adversaries and component failures inevitably bypass initial barriers. Without detective controls, breaches remain hidden for months; without corrective controls, organizations suffer catastrophic unrecoverable damage.

🛡️ **GRC Auditor Perspective:** Auditors review Incident Response Plans (IRP) and Business Continuity procedures: inspecting SIEM alerting rules and IDS telemetry to measure Mean Time to Detect (MTTD - Detective), while validating periodic backup restoration drills and failovers to measure Mean Time to Recover (MTTR - Corrective).

⚠️ **How CompTIA Tests This:** Classic CompTIA exam trap: Fire extinguishers and restoring backups are CORRECTIONAL / CORRECTIVE (deployed during or after the incident begins). CCTV recording footage is DETECTIVE (provides forensic evidence). IDS is Detective; IPS is Preventive.

📌 Compensating Controls: The Alternative Safeguard

🏠 **Real-World Analogy:** Imagine a warehouse cargo elevator breaking down with replacement components backordered for two weeks. To prevent operations from halting without forcing staff to carry heavy pallets down steep stairs risking severe injury, management rents an industrial conveyor belt accompanied by two dedicated safety monitors to escort every payload.

🔍 **Root Cause & Background:** Organizations frequently operate legacy operational technology (such as medical devices or SCADA controllers) that architecturally cannot support mandated modern controls (like MFA or strong ciphers), necessitating substitute compensating measures to achieve equivalent risk mitigation.

🛡️ **GRC Auditor Perspective:** Under compliance frameworks like PCI-DSS, auditors require a formal Compensating Control Worksheet (CCW): documenting the legitimate technical or economic constraint, proving that the alternate safeguard provides equivalent risk reduction (e.g., strict VLAN isolation with dedicated IPS), and verifying formal risk committee sign-off.

⚠️ **How CompTIA Tests This:** Exam scenario cue: 'Legacy operating system cannot support multifactor authentication / Organization deploys an alternative security measure to achieve equivalent protection'. The correct choice is Compensating Control.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Visible CCTV security camera with warning sign at entrance	**Deterrent Control**
Access turnstile with biometric reader that physically locks out intruders	**Preventive & Physical Control**
Using a fire extinguisher or restoring clean system backups after ransomware	**Corrective Control**
Audit log review and alerts triggered by an automated SIEM or IDS	**Detective & Technical Control**
Isolated VLAN with dedicated monitoring for legacy server that cannot be patched	**Compensating Control**
Acceptable Use Policy (AUP) formally signed by all corporate employees	**Managerial & Directive Control**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A network engineer configures the perimeter firewall to deny inbound TCP 445 from the internet after a vulnerability assessment. Which of the following BEST describes this control?

A) Technical preventive

B) Physical deterrent

C) Managerial corrective

D) Operational detective

QUESTION 2 · EXAM SCENARIO

A CISO updates the organization's acceptable use policy to require all employees to report suspected phishing emails to the security team within 15 minutes. Which of the following BEST describes this control?

A) Technical preventive

B) Managerial directive

C) Operational detective

D) Physical compensating

QUESTION 3 · EXAM SCENARIO

The security team deploys a SIEM rule that correlates failed VPN logins and sends an alert when 10 failures occur from the same IP address in 5 minutes. Which of the following BEST describes this control?

A) Physical preventive

B) Managerial deterrent

C) Technical detective

D) Operational corrective

QUESTION 4 · EXAM SCENARIO

After a ransomware incident, the team restores affected servers from immutable backups and rebuilds the domain controller. Which of the following BEST describes this control?

A) Detective

B) Preventive

C) Deterrent

D) Corrective

QUESTION 5 · EXAM SCENARIO

A data center places highly visible warning signs stating 'Authorized Personnel Only' and installs flashing cameras at entrances to discourage trespassers. Which of the following BEST describes this control?

A) Preventive

B) Deterrent

C) Detective

D) Compensating

QUESTION 6 · EXAM SCENARIO

A company cannot upgrade a legacy medical device to support multifactor authentication. To reduce risk, security places the device on an isolated VLAN, restricts access to a jump host, and monitors all sessions. Which of the following BEST describes this control?

A) Compensating

B) Directive

C) Corrective

D) Detective

QUESTION 7 · EXAM SCENARIO

A government facility installs a mantrap with two interlocking doors and a badge reader at the entrance to the server room. Which of the following BEST describes this control?

A) Operational deterrent

B) Technical detective

C) Managerial compensating

D) Physical preventive

QUESTION 8 · EXAM SCENARIO

The security department conducts quarterly phishing simulation training for all staff and performs tabletop incident response exercises with department leads. Which of the following control categories BEST describes these activities?

A) Technical

B) Managerial

C) Operational

D) Physical

QUESTION 9 · EXAM SCENARIO

A hospital posts a policy in each ward stating that patient data must only be accessed on approved devices and only when clinically necessary; staff must acknowledge it annually. Which of the following control types BEST describes this control?

A) Directive

B) Preventive

C) Detective

D) Corrective

QUESTION 10 · EXAM SCENARIO

A data center installs infrared motion sensors and door contacts that trigger an alarm when movement is detected after hours. Which of the following BEST describes this control?

A) Physical preventive

B) Physical detective

C) Operational deterrent

D) Technical corrective

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Technical preventive

A firewall is a technical control because it is implemented through technology. Denying inbound SMB traffic (TCP 445) blocks the activity before it can reach internal systems, making it preventive.

Question 2: Option B — Managerial directive

The acceptable use policy is a managerial control because it is a formal document that governs behavior. It directs employees to take a specific action, so it is also directive.

Question 3: Option C — Technical detective

A SIEM correlation rule is a technical control because it uses a security tool. It identifies suspicious authentication activity and alerts analysts, so it is detective.

Question 4: Option D — Corrective

Restoring from backups and rebuilding systems occur after an incident to return operations to normal. This makes the control corrective.

Question 5: Option B — Deterrent

Warning signs and visible cameras discourage individuals from attempting unauthorized access. The primary purpose is to deter, so this is a deterrent control.

Question 6: Option A — Compensating

Because the preferred control (MFA) cannot be implemented on the legacy device, the organization uses isolation, a jump host, and monitoring as an alternative risk reduction measure. This is a compensating control.

Question 7: Option D — Physical preventive

A mantrap, interlocking doors, and badge reader are physical barriers that prevent unauthorized entry before access is granted. This is a physical preventive control.

Question 8: Option C — Operational

Awareness training and tabletop exercises are day-to-day people-driven activities, making them operational controls. They do not rely primarily on technology, formal policy documents alone, or physical barriers.

Question 9: Option A — Directive

The policy instructs staff on required behavior and access conditions. Because its primary purpose is to direct actions rather than technically enforce or monitor them, it is a directive control.

Question 10: Option B — Physical detective

Infrared motion sensors and door contacts are physical controls used to identify unauthorized activity after it occurs. Their primary purpose is to detect intrusions, making this a physical detective control.